

LLbezpeky: Leveraging Large Language Models for Vulnerability Detection

Noble Saji Mathews

University of Waterloo, Canada
noblesaji.mathews@uwaterloo.ca

Yelizaveta Brus

University of Waterloo, Canada
ybrus@uwaterloo.ca

Yousra Aafer

University of Waterloo, Canada
yousra.aafer@uwaterloo.ca

Meiyappan Nagappan

University of Waterloo, Canada
mei.nagappan@uwaterloo.ca

Shane McIntosh

University of Waterloo, Canada
shane.mcintosh@uwaterloo.ca

Abstract

Despite the continued research and progress in building secure systems, Android applications continue to be ridden with vulnerabilities, necessitating effective detection methods. Current strategies involving static and dynamic analysis tools come with limitations like overwhelming number of false positives and limited scope of analysis which make either difficult to adopt. Over the past years, machine learning based approaches have been extensively explored for vulnerability detection, but its real-world applicability is constrained by data requirements and feature engineering challenges. Large Language Models (LLMs), with their vast parameters, have shown tremendous potential in understanding semantics in human as well as programming languages. We dive into the efficacy of LLMs for detecting vulnerabilities in the context of Android security. We focus on building an AI-driven workflow to assist developers in identifying and rectifying vulnerabilities. Our experiments show that LLMs outperform our expectations in finding issues within applications correctly flagging insecure apps in 91.67% of cases in the Ghera benchmark. We use inferences from our experiments towards building a robust and actionable vulnerability detection system and demonstrate its effectiveness. Our experiments also shed light on how different various simple configurations can affect the True Positive (TP) and False Positive (FP) rates.

1 INTRODUCTION

Despite advancements in building secure systems and extensive research in the area, Android applications remain prone to a range of vulnerabilities and even vulnerability reintroduction for fixed issues [1, 5], creating a pressing demand for effective vulnerability detection methodologies. Current approaches to tackle this primarily revolve around static and dynamic analysis tools [10]. However, they have their distinct limitations, such as vast false positives in the case of static analysis tools [3] and an overwhelming amount of effort that goes into building these frameworks and adapting them to newer vulnerability types.

In the past few years, there have also been numerous explorations into the use of machine learning to uncover

vulnerabilities [10], however, the applicability of these remains limited in real-world settings due to the vast amount of training data required and an explicit focus on feature engineering to approximate the complexity of the systems being analyzed. With the advent of LLMs, huge billion parameter models have pushed the boundaries of what was thought achievable through an Artificially Intelligent system. These are believed to acquire “embodied knowledge about syntax, semantics, and ontology inherent in human language” [8] and have also shown significant power when dealing with programming languages due to their relatively simpler underlying Grammar and Semantics [6]. This brings a question to mind, How good are these Language Models at detecting vulnerabilities?. There have been several recent explorations into the use of these large language models and improving their efficacy for vulnerability detection in general, and these have shown promising results [9].

Current work in the literature has looked at the performance of GPT-based models for the task of vulnerability detection in code [4], Cheskov et al. report it to be not very effective but they employ a very simplistic approach. Other recent work has shown that extended prompting and LLM-driven methods complemented by other techniques have yielded more accurate results than simple prompting for detecting CWEs present in code [2, 11]. There has also been a much more detailed exploration that looks into various aspects of using LLMs for software security with promising results [14].

We explore this area further in the context of Android Security, attempting to build an AI-enabled workflow that would enable developers to detect and aide in remediating vulnerabilities or even aid developers in writing secure code by acting as a pair programmer. Do note that fine-tuning models or training our own LLM is out of scope of this research, we primarily seek to explore if and how the latent knowledge present in these LLMs can be used for Android analysis.

For this exploration into the use of new and emerging technologies it is critical we lay out a few fundamental questions, to begin with, and direct our efforts. We attempt to answer as

many of the following as possible based on insights gained from this exploration:

- **RQ1: Can LLMs detect Android vulnerabilities with basic prompting techniques?**
 - If so how good are they at this compared to existing tools?
 - What kind of vulnerabilities are LLMs good at uncovering? Can these systems detect newer vulnerabilities that are less well-known?
 - Do we require fine-tuning of either the Model or the embeddings to achieve better results?
- **RQ2: What kind of Input would such a system need to be able to understand and discover issues in the code?**
 - How could we supply this additional context? What kind of Knowledge bases would aid LLMs in discovering complicated bugs? (API Usage, Permissions Involved, Framework Endpoints, Cross-language and dynamic components)
 - Can existing solutions / static tools be used in tandem with these LLMs? or is it better to address only some classes of vulnerabilities with each type of approach?

To build out such a workflow there are 2 key elements we need to address (We give a brief overview of these in the following sections)

- How do we get LLMs (particularly Instruct Trained Models) to do what we want? -> **Prompt Engineering**
- How do we supply the code and additional context to an LLM -> **Retrieval Augmented Generation**

1.1 PROMPT ENGINEERING

Prompt Engineering, a novel technique in artificial intelligence, is instrumental in enhancing the efficacy of language models for specific tasks. It involves intricate prompt construction that optimizes AI performance by eliciting improved responses [13]. One groundbreaking strategy within Prompt Engineering is the Chain-of-Thought Prompting introduced by Wei et al. (2022) [12]. This approach pushes the boundary of AI's reasoning by guiding the model through a sequence of prompts that enrich and build upon each other. It allows for more depth in AI reasoning, particularly when paired with few-shot prompting, proving useful for complex tasks that necessitate multiple stages of reasoning.

1.2 RETRIEVAL-AUGMENTED GENERATION

Retrieval Augmented Generation (RAG) is an AI framework designed to enhance the quality of responses generated by large language models (LLMs) [7]. RAG allows LLMs to build on a specialized body of knowledge to answer questions more accurately. It's like giving the model an open-book exam, where it can browse through content in a book, as opposed to trying to remember facts from memory. In our

case, this knowledge base would be specific to Android and could include any or all of the following:

- Additional code that needs to be fetched from a large codebase
- Static / Code analysis results that could prove useful to comment about a specific issue
- Documentation and additional information that allows the LLM to garner a better understanding of the system and task at hand

We initially focus our efforts on prompt engineering to leverage the LLM's knowledge for tracing Android vulnerabilities. We attempt to compare the detection capability of the LLM with other strategies on the same set of applications, thereby providing insights on which approach can uncover more vulnerabilities with fewer false positives. We use these insights to continually update and improve the instructions used for prompting over the course of the experiments.

In order to do this we need a benchmark dataset designed to test Android Security Analysis tools. For this study we target smaller apps that replicate individual vulnerability types. However to understand our design objectives we need to structure our pipeline so it can logically be extended to real applications. In the next section we move on to a case study attempting detection in an app that has multiple seeded vulnerabilities. This involves integrating retrieval mechanisms for obtaining additional context that can significantly enhance the feasibility and performance of such systems. Retrieval mechanism are critical in real-world scenarios when dealing with larger applications due to the limited token window of present-day LLMs. Hence it is also important that we focus on optimising the size of the input to the model while ensuring the LLM has enough context to make a sound decision.

2 METHODOLOGY



In our study, experiments were conducted with GPT-4, using the Ghera benchmark ¹ as the dataset. We use GPT4 for our experiments as it is one of the most powerful available LLMs as of today. In our limited experiments with GPT3.5 it struggles with following instructions properly. Further we also setup our experiments to work with Open LLMs but as of writing this report open models like Llama 2 perform significantly worse compared to their paid counterparts. Hence we stick with our decision to employ GPT4 despite the higher costs incurred for inferences. Throughout the iterations, we refine the prompts, enhancing the information provided to the model, including specific details about vulnerabilities. In the final experiment, only "AndroidManifest.xml" and "MainActivity.java" files if they exist in the analyzed project were presented to the model. We also provide a list of additional files present in the project. We also experiment with summarizing the content of files and providing that information

¹Ghera Dataset

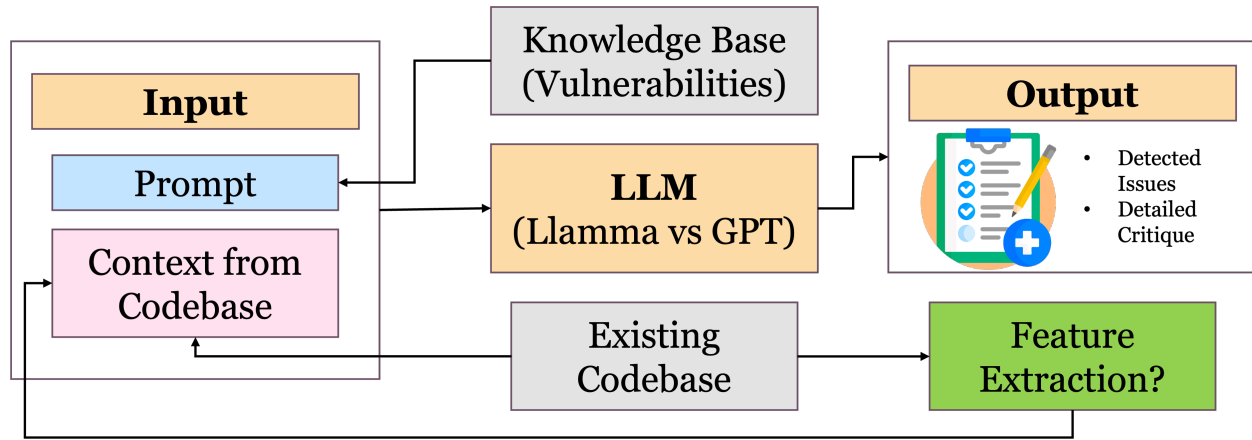


Figure 1. Rough Architecture of Experiments

to the model as well. We also implemented functionality to allow the model to request the content of specific files if necessary for further vulnerability identification.

Ghera is a benchmark repository that predominantly catalogs vulnerabilities previously identified in Android applications, as established in existing literature. This repository is distinctively organized into benchmarks, each targeting a specific vulnerability. These benchmarks comprise three types of applications: a benign application that possesses the vulnerability, a malicious application designed to exploit this vulnerability, and a secure application that is immune to such exploitation. The benchmarks are practical, including instructions for building and executing the applications, thereby allowing for the empirical verification of the vulnerabilities and their corresponding exploits. Presently, Ghera’s collection exclusively consists of ‘lean’ benchmarks, which are minimalistic apps specifically designed to showcase the vulnerabilities and their exploits, without incorporating additional complex functionalities. Ghera contains 69 different issues as of date that can be categorized into the following types:

- **Crypto:** Vulnerabilities in app encryption methods, including block cipher issues and exposed encryption keys.
- **ICC:** Risks in app communication components, such as dynamic receivers and intent hijacks.
- **Networking:** Security issues in app network communications, including certificate mishandling and MitM attack susceptibility.
- **NonAPI:** Vulnerabilities due to outdated libraries and inherited library flaws in apps.
- **Permission:** Security risks from unnecessary or weak app permissions leading to potential unauthorized access.

- **Storage:** Data storage vulnerabilities in apps, including external/internal storage risks and SQL injection threats.
- **System:** System-related vulnerabilities in apps, focusing on privilege escalation and information exposure.
- **Web:** Web component vulnerabilities in apps, such as MitM attack risks and code injection in WebViews.

During the experimentation process, we found that the Ghera benchmarks contained explicit indications of “Benign” and “Secure” in both the file paths and the content. For our experiments to be valid and to minimize data leakage to the LLM about the ground truth, we replaced these values with “llbezpekymyapp” and “llsezpekymyapp” respectively. However, we include our insights from runs in Experiments 1 and 2 that had the leaked data to see how much it influences the results. Interestingly leakage of the word secure clearly influenced the outcomes and highlighted the need for clearly sanitizing the data from semantic names that can mislead the LLM’s reasoning. Do note that folder names still indicate the kind of vulnerability to some extent but this shouldn’t be a cause of concern in any of the subsequent experiments. Our analysis of these experiments and their outcomes will be described in the following section.

3 RESULTS

In this section, we discuss the various experiments conducted, the thought processes behind them, and the insights obtained.

3.1 Experiment 1: Basic Prompting GPT4

For this experiment, we explore basic prompting without providing any information about the vulnerability. We wish to figure out what kind of vulnerabilities if any GPT could detect without any explanation about the issue. Results are shown in Table 1.

	Leaked Data		Cleaned Data	
	Insecure	Secure	Insecure	Secure
Flagged insecure	54	21	58	56
Flagged secure	5	38	1	3
Undecidable	1	0	1	0
Overall	60	59	60	59

Table 1. Results of Experiment 1

It is interesting to note that even without any details about the vulnerability GPT4 could flag apps as insecure. However, it seems that the model just has a tendency toward marking apps as insecure as can be seen with secure apps in the cleaned dataset. We note that even though 58 out of 60 insecure are correctly identified with relevant snippets being highlighted 56 of the 59 secure apps are misclassified.

3.2 Experiment 2: Providing a summary of the vulnerability

In this experiment, we check if the model can verify the presence of specific vulnerabilities given a very brief summary. We hypothesize that specifying limited details about issues we are looking for would lead to context activation² and enable the LLM to use its existing knowledge towards analysis. Therefore, we extended experiment 1 by providing short information about a vulnerability and the obtained results are shown in Table 2. This process involves creating brief textual descriptions that encapsulate how each vulnerability functions or why an app is susceptible to it. These summaries are crucial as they offer an initial understanding without the need for detailed, app-specific descriptions, which may not be readily available in real-world scenarios. Such summaries might be akin to Common Weakness Enumeration (CWE) descriptions, providing essential insights at a glance.

	Leaked Data		Cleaned Data	
	Insecure	Secure	Insecure	Secure
Flagged insecure	53	6	55	34
Flagged secure	6	52	3	24
Undecidable	1	1	2	1
Overall	60	59	60	59

Table 2. Results of Experiment 2

We see that with just a short summary of the vulnerability we are able to improve on the number of Secure apps flagged as insecure by a significant margin. Another thing that can be noted from Figure 2 is that Experiment 2 actually reduces the time consumed by the model to return an inference both on secure and benign apps. We notes than we have a TP rate of 66.38% in this case as compared to 51.26% in the previous experiment (we consider undecidable as a misclassification).

²In-Context Learning

3.3 Experiment 3: Requesting files as and when required

For previous experiments we were sending all the needed files, we cannot use such techniques for real-world applications. Hence, we modified the prompt, so the model asks to provide more information if needed. Results are shown in Table 3. We initially focus on the AndroidManifest.xml and MainActivity.java files, recognizing that while vulnerabilities often reside deeper in the code, these files can provide vital starting points for analysis. From here, the model can request additional files as needed, thereby initiating the Retrieval Augmented Generation process in a structured manner.

Our approach includes providing a summary of all files in the application, with the exception of the Manifest and the MainActivity file. The summary is generated by the LLM itself in a preprocessing step. The LLM is then enabled to request the content of specific files based on these summaries. This selective process is particularly useful in identifying vulnerabilities that might be indicated by exported components or specific implementations in the code. This methodology is a form of Retrieval Augmented Generation though at a very coarse granularity, aiming to probe its impact on the efficiency and accuracy of vulnerability detection.

The undecidable case in this experiment requires the build.gradle file and the "libs" folder and even though that is correctly requested we currently only include code within "app/src/main" and address this in the final architecture. We noticed that the model tends to ask for all files when implemented in a simple fashion so we ended up creating an alternate chain that summarizes all the files and includes this summary with the list of files. This actually had the opposite effect with the model never requesting any file in most cases. We justify the lower TP rates of 60.5% due to hallucinations made by the model based on the summaries. Another thing to note is that even though the impact is not significant, the generated reports lack clarity due to not having access to the exact implementation details. However there are clearly efficiency gains to an approach like this though while sacrificing on the quality of the report generated.

	Cleaned Data	
	Insecure	Secure
Flagged insecure	57	43
Flagged secure	2	15
Undecidable	1	1
Overall	60	59

Table 3. Results of Experiment 3

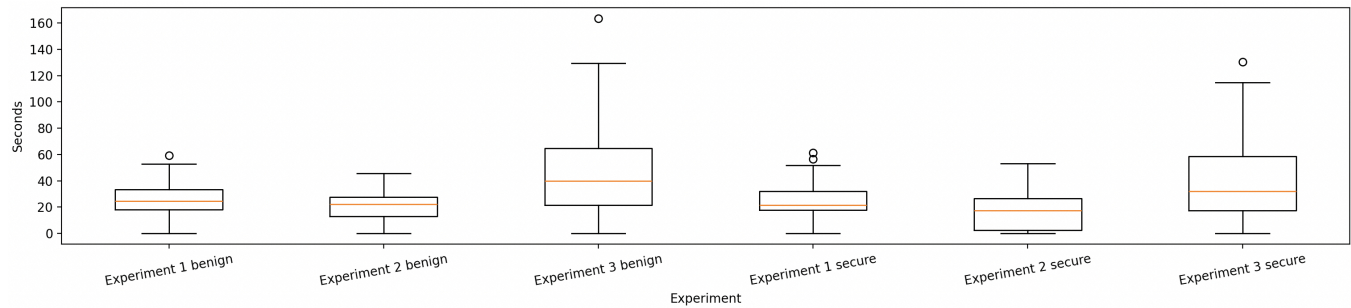


Figure 2. Time consumed for each inference



Key Takeaways: From our experiments we see that given sufficient context GPT4 can successfully identify vulnerabilities. Summarizing clearly saves significantly on the costs, since the summaries can be used across scanners and is a one-time cost. Attempts at reducing the amount of information still need work and we need a critique process to deal with the models tendency to mark applications as insecure.

4 LLB ANALYZER

We use the insights from the experiments to put together a python package called “LLB”, which can be invoked to run the the pipeline on any target android application. The package is designed to facilitate the scanning of Android projects for security vulnerabilities. It employs a Command Line Interface (CLI) as shown in Figure 3, leveraging the Typer framework to provide an intuitive user experience. This package integrates distinct scanning mechanisms, offering flexibility and comprehensiveness in the vulnerability assessment process.

The core functionality of "llb" is encapsulated in the scan command. This command allows users to specify the target Android application directory for analysis. In alignment with the package's focus on adaptability, it incorporates multiple scanner options, namely 'GHERA' and 'VULDROID', along with an 'all' option to execute all available scanners. These scanners are tailored to identify different categories of vulnerabilities, ensuring a thorough examination of the target application. The scan command also supports an output directory specification, where the results of the scan are systematically compiled and stored. This feature is critical for maintaining a record of the vulnerabilities identified and serves as a reference for further analysis or remediation efforts. An example of a part of the report generated by LLB is shown in Figure 4.

In addition to its scanning capabilities, "llb" includes the expert command. This command is particularly useful for

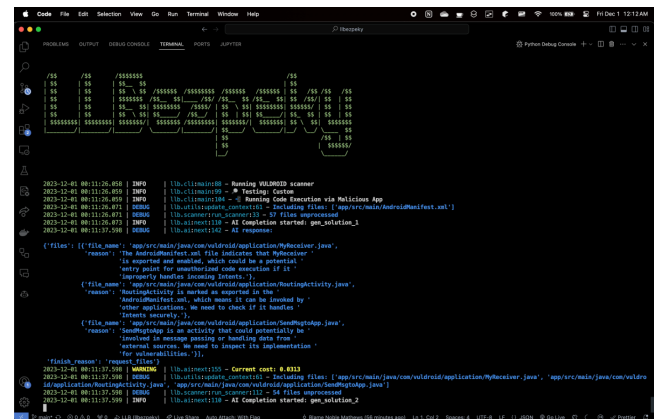


Figure 3. LLB Python package running through CLI

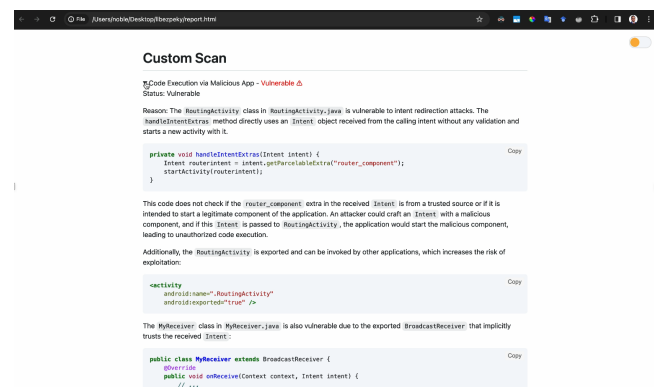


Figure 4. Example from case study report generated by LLB

post-scan analysis, allowing users to append expert comments or insights to the generated reports. This feature underscores the package's utility in collaborative environments, where multiple stakeholders, including security analysts and developers, might interact with the scan results.

5 Case study

5.1 Flagged Vulnerability: Deep dive

Let us look at the analysis report for case “WebView NoUser-Permission InformationExposure” in Ghera. In mobile app security, it’s crucial to handle sensitive user data carefully. In this case we have a simple web browser that allows web pages to access the device’s location via a GPSTracker API. The API’s `getLatitude()` method can be triggered by JavaScript on a webpage to fetch the user’s latitude without asking for the user’s consent each time. This creates a vulnerability: a malicious webpage could use this method to secretly track a user’s location. To mitigate this risk, apps must not only ask for user permission to access sensitive data initially but also maintain strict control over its access during use, particularly when dealing with potentially untrustworthy web content.

```

1 @JavascriptInterface
2 public double getLatitude() {
3     if (location != null) {
4         return location.getLatitude();
5     } else {
6         // return dummy value
7         return 42.42;
8     }
9 }

```

Listing 1 Information Exposure snippet flagged by LLB as indicated in the Ghera benchmark

In this case LLB correctly identifies the concerning snippet shown in Listing 1. LLB returns the reason as follows: “The application is vulnerable because it exposes sensitive information (GPS location) to the JavaScript code running in the WebView without explicitly asking the user for permission... The application does request the `ACCESS_FINE_LOCATION` permission, but it does not inform the user that their location will be accessible to any malicious JavaScript code running in the WebView.” and also provides a suggested fix to remediate the issue.

5.2 Misclassification: Deep dive

A common trend which we observed among misclassified samples was that they either were flagged for bad patterns in code which might not necessarily be considered vulnerable by an expert in the context we are analysing. Let us look at a case where the LLM was thrown off. The initial classification of the code as “Vulnerable” due to lack of sanitization checks on the file paths seems to be based on a misunderstanding. In the provided snippet, the file name `fileNm` is hard-coded to “demo.txt”, and there’s no indication that it is influenced by external inputs or user-provided data. Therefore, the specific concern of path traversal, where an attacker could manipulate file paths to access unauthorized directories, does not apply here.

It’s likely that the Language Model (LLM) that made the initial classification may have been “thrown off” due to the

```

1 String fileNm = "demo.txt";
2 // ...
3
4 if (i != null && i.getStringExtra("fileName") !=
    null && !i.getStringExtra("fileName").equals("")
    )
5     && i.getStringExtra("fileContent") != null && !i.
        getStringExtra("fileContent").equals("")
6     && i.getStringExtra("fileName").equals(fileNm)) {
7         fileContent = i.getStringExtra("fileContent");
8     } else {
9         setResult(RESULT_CANCELED);
10        return;
11    }
12 // ...
13
14 File file = new File(dir, fileNm);
15 try (FileWriter fileWriter = new FileWriter(file)) {
16     fileWriter.append(fileContent);
17 } catch (IOException e) {
18     Toast.makeText(getApplicationContext(), "IOError
19         while writing", Toast.LENGTH_SHORT).show();
20     setResult(RESULT_CANCELED);
21     e.printStackTrace();
22 }
23 // ...

```

Listing 2 Misclassified example in Ghera

common pattern of vulnerabilities associated with file handling operations, especially when they involve input from intents or external sources. When it sees code that interacts with file systems, there may be an overcautious approach to flag potential security risks, such as path traversal.

The expert follow-up correctly clarifies that, in this specific case, there is no direct vulnerability present in the snippet due to the fixed file name. Using the expert comment we are able to set the analyzer on the right track even in other cases and give a more relevant suggestion if required.

5.3 Vuldroid

In order to analyze a full application with multiple known vulnerabilities we chose to conduct a case study on Vuldroid. Vuldroid is a vulnerable Android application, which contains only security issues. The app consists of the following vulnerabilities:

- **Steal Password MagicLoginLinks (V1).** This vulnerability allows a malicious app to intercept password reset tokens or magic login links. This is possible because the app doesn’t properly restrict which activities can handle deep links, allowing an external app to capture these sensitive tokens.
- **Webview Xss via Exported Activity (V2).** Here, the vulnerability lies in an exported activity that loads web content. Since the activity doesn’t validate the URLs it loads, a malicious app can pass a script (like a JavaScript prompt) through an intent, leading to a cross-site scripting (XSS) attack.
- **Webview Xss via DeepLink (V3).** Similar to the previous one, this exploit involves XSS attacks but through

deep links. The app fails to validate deep link URLs, allowing the injection of malicious scripts via query parameters in these URLs.

- **Stealing Files via Webview (V4).** This issue arises because the app’s webview settings allow access to local file URLs (file:///). By crafting a specific URL, an attacker can access and transmit local files to a remote server.
- **Stealing Files via Fileprovider (V5).** The FileProvider is misconfigured to expose all paths, and combined with an exported activity, it allows other apps to access and steal files.
- **Intent Sniffing Between Two Applications (V6).** This vulnerability occurs when two apps communicate using intents without proper security checks. A malicious app can intercept these intents and access the transmitted data.
- **Reading User Email via Broadcasts (V7).** Due to an exported broadcast receiver in the app, a malicious app can trigger this receiver and access the user’s email information.
- **Command Execution via Malicious App (V8).** This vulnerability allows a malicious app to execute unauthorized commands or operations within the vulnerable app. The details of this exploit weren’t fully described in your summary.

The results of the case study are described in Table 4. The meaning of the symbols:

- C - vulnerability was detected
- W - the provided information wasn’t enough for the LLM to make the decision.
- X - vulnerability wasn’t detected

V1	V2	V3	V4	V5	V6	V7	V8
W	C	C	C	W	C	C	C

Table 4. Results of case study

We note that running LLB on the Vuldroid source code we correctly identify 6 of the 8 seeded vulnerabilities. The 2 which couldn’t be classified were because the analyzer could not find the relevant snippets for analyzing by requesting files. For the remaining 6 cases the correct snippet is identified and a valid fix is also suggested in most cases. Thus the LLB report doesn’t just tag vulnerable applications but actually walks you through the reasoning involved and how to fix the flagged issue.

6 DISCUSSION AND FUTURE WORK

The field of leveraging Large Language Models (LLMs) to enhance Software Engineering tools and improve our understanding of large projects is a very active research area. There are numerous parameters and processes that can be

optimized based on the specific functionality desired. We explore a basic prompting strategies for LLB however a more structured pipeline with multiple agents could significantly improve the performance of LLB as an analyzer. We also wish to highlight that each vulnerability we scan for is considered as a single scanner and there is clear value to exploring making this process less resource intensive by sharing information between scanners and choosing which ones to run based on the type of codebase and artifacts present within it.

We also wish to compare the results with those obtained from existing approaches in an empirical study. While our current framework does not integrate static analysis, we acknowledge its potential value and are considering its incorporation in future iterations. Overarching the entire methodology is a constant focus on improving software vulnerability identification, reducing false positive rates, and streamlining the process of enhancing Android app security. We believe our study serves as a basis to attempts to merge state-of-the-art language models with static analysis, potentially establishing a more reliable, accurate, and efficient android vulnerability detection approach. “What existing tools and code level analysis results can be supplied to the LLM to take a more informed decision?” remains an open question.

The results of the LLB case study on vuldroid highlights a shortcoming in the current implementation. This can be easily handled by indexing the code into a vector database and allowing vector search and retrieval to identify relevant files rather than building outwards from a set of files. Further summaries were not incorporated in the LLB package due to their tendency to induce hallucinations in the report. We plan to address this by increasing our granularity to a file level and incorporating critique mechanisms like have been employed in recent works in other domains that attempt to leverage LLMs.

7 THREATS TO VALIDITY

Prompt engineering, while a powerful tool to guide LLMs, is also subject to limitations. The effectiveness of prompt engineering is heavily reliant on the skill and experience of the user. Poorly designed prompts can lead to suboptimal results, as the model’s responses are only as good as the questions posed. There’s also the risk of introducing bias through prompts, which can skew the model’s focus and potentially overlook certain types of vulnerabilities.

A point which we highlighted earlier is about leaking semantic information about the class of the problem due to artifacts in the code. We replace keywords to clean our data but there could be implicit data that leaks this information to the LLM which we might not have accounted for in our analysis. Further capability of LLMs is very diverse with some performing drastically different compared to others. While we set seeds to ensure replicability of our results these can vary drastically over time.

Another concern is the dynamic nature of both Android platform and cybersecurity threats. As Android continuously evolves, new types of vulnerabilities emerge, which may not be immediately recognized by an LLM trained on outdated data. Similarly, cyber threats are constantly evolving, with attackers devising new methods to exploit systems. This requires continuous updates and retraining of the LLM, which can be resource-intensive.

8 CONCLUSION

In our research, we explore the utilization of Large Language Models (LLMs) for detecting Android vulnerabilities. We successfully demonstrate the power of LLMs for Android Vulnerability detection and remediation. Our experiments using Prompt Engineering on the Ghera Vulnerability Dataset show promising results and bring up new and interesting directions which can be explored towards improving the efficacy of such systems. Further we utilize the results and insights from our experiments to create a highly configurable python package that allows easy modification of the LLM being used as the reasoning engine and also supports extension to multi-agent architectures. In terms of the questions we set out to answer it is clear that LLMs are incredibly powerful tools that can revolutionize Software Engineering tools as we know them, but it also clear that they do not work magic out of the box and clearly require work in terms of drafting and structuring a better analysis pipeline architecture and optimising the context available to the LLM.

9 ACKNOWLEDGEMENTS

This project report is a part of the course CS858 at the University of Waterloo. I express my sincere gratitude to my course instructor, Yousra Aafer, for her invaluable guidance and support throughout this project. Her expertise and insights have been fundamental in shaping the research and its outcomes.

I would also like to extend my thanks to my supervisors, Meiyappan Nagappan and Shane McIntosh. Their input and feedback have been instrumental in refining the research methodologies and enhancing the overall quality of this work. Their perspectives and suggestions have greatly contributed to the depth and rigor of the research.

I am thankful for the collaborative environment provided by the University of Waterloo, which has been conducive to academic exploration and innovation. The resources and support offered by the university have played a crucial role in the successful completion of this project.

Lastly, I appreciate the efforts of all those who have directly or indirectly contributed to this research, including my peers for their constructive criticisms and the university staff for their administrative support.

References

- [1] Sumaya Almanee, Arda Ünal, Mathias Payer, and Joshua Garcia. 2021. Too quiet in the library: An empirical study of security updates in android apps' native code. In *2021 IEEE/ACM 43rd International Conference on Software Engineering (ICSE)*. IEEE, 1347–1359.
- [2] Owura Asare. 2023. *Security Evaluations of GitHub's Copilot*. Master's thesis. University of Waterloo.
- [3] Wang Chao, Li Qun, Wang XiaoHu, Ren TianYu, Dong JiaHan, Guo GuangXin, and Shi EnJie. 2020. An android application vulnerability mining method based on static and dynamic analysis. In *2020 IEEE 5th Information Technology and Mechatronics Engineering Conference (ITOEC)*. IEEE, 599–603.
- [4] Anton Cheshkov, Pavel Zadorozhny, and Rodion Levichev. 2023. Evaluation of ChatGPT Model for Vulnerability Detection. *arXiv preprint arXiv:2304.07232* (2023).
- [5] Jun Gao, Li Li, Pingfan Kong, Tegawendé F Bissyandé, and Jacques Klein. 2019. Understanding the evolution of android app vulnerabilities. *IEEE Transactions on Reliability* 70, 1 (2019), 212–230.
- [6] Xinyi Hou, Yanjie Zhao, Yue Liu, Zhou Yang, Kailong Wang, Li Li, Xiapu Luo, David Lo, John Grundy, and Haoyu Wang. 2023. Large Language Models for Software Engineering: A Systematic Literature Review. *arXiv preprint arXiv:2308.10620* (2023).
- [7] Patrick Lewis, Ethan Perez, Aleksandra Piktus, Fabio Petroni, Vladimir Karpukhin, Naman Goyal, Heinrich Küttler, Mike Lewis, Wen-tau Yih, Tim Rocktäschel, et al. 2020. Retrieval-augmented generation for knowledge-intensive nlp tasks. *Advances in Neural Information Processing Systems* 33 (2020), 9459–9474.
- [8] Christopher D Manning. 2022. Human language understanding & reasoning. *Daedalus* 151, 2 (2022), 127–138.
- [9] David Noever. 2023. Can Large Language Models Find And Fix Vulnerable Software? *arXiv preprint arXiv:2308.10345* (2023).
- [10] Janaka Senanayake, Harsha Kalutarage, Mhd Omar Al-Kadri, Andrei Petrovski, and Luca Piras. 2023. Android source code vulnerability detection: a systematic literature review. *Comput. Surveys* 55, 9 (2023), 1–37.
- [11] Jin Wang, Zishan Huang, Hengli Liu, Nianyi Yang, and Yinhao Xiao. 2023. DefectHunter: A Novel LLM-Driven Boosted-Conformer-based Code Vulnerability Detection Mechanism. *arXiv preprint arXiv:2309.15324* (2023).
- [12] Jason Wei, Xuezhi Wang, Dale Schuurmans, Maarten Bosma, Fei Xia, Ed Chi, Quoc V Le, Denny Zhou, et al. 2022. Chain-of-thought prompting elicits reasoning in large language models. *Advances in Neural Information Processing Systems* 35 (2022), 24824–24837.
- [13] Jules White, Quchen Fu, Sam Hays, Michael Sandborn, Carlos Olea, Henry Gilbert, Ashraf Elnashar, Jesse Spencer-Smith, and Douglas C Schmidt. 2023. A prompt pattern catalog to enhance prompt engineering with chatgpt. *arXiv preprint arXiv:2302.11382* (2023).
- [14] Chenyuan Zhang, Hao Liu, Jiutian Zeng, Kejing Yang, Yuhong Li, and Hui Li. 2023. Prompt-Enhanced Software Vulnerability Detection Using ChatGPT. *arXiv preprint arXiv:2308.12697* (2023).